

Lab 3: Commanding the Ship - Roles and Responsibilities in Security Governance

Course: GRC102 - Information Security Governance
Week: 3

Student Name: JOY ORILADE

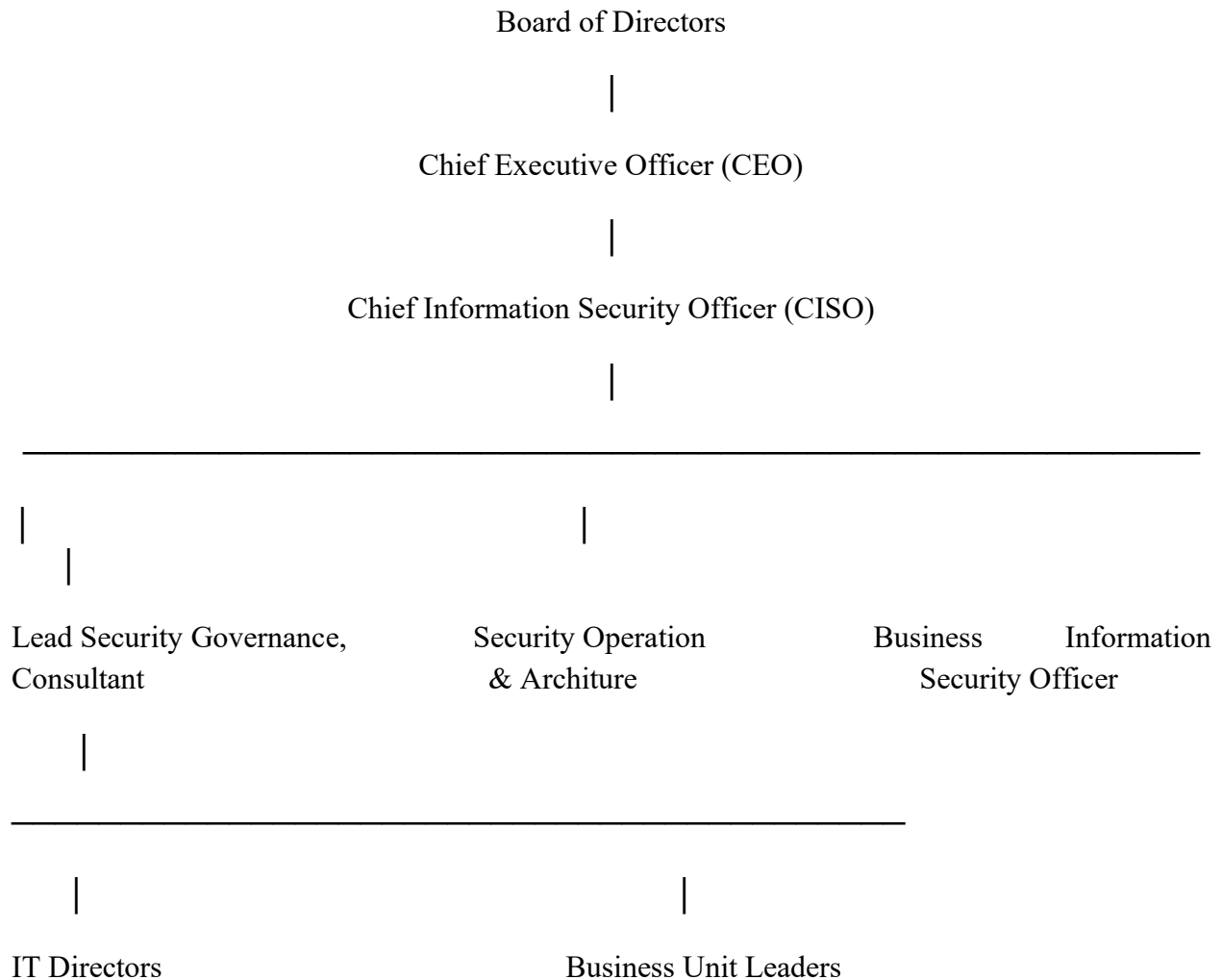
Date: 18th March, 2026

Instructor: Com Idris Aminu

Deliverables for Task 1

1. **Security Governance Org Chart:** A clear diagram showing reporting lines and communication paths.

ANSWER



1. Analyze the Gaps: Identify the top 3 risks of TechGlobal's current "informal" approach.

ANSWER

1. Security strategy" is just the IT Director making every single decision on the fly: The IT director is overwhelmed as making every single decision leading to inconsistent, delayed or biased towards security priorities rather than risk. Being the sole decision making, this led to lack of accountability, lack of scalability, and decision bottlenecks.
2. There are no formal committees, business units are doing their own thing: without formal or structural committees, business units implement their own controls and there is a high risk of vulnerabilities and compliance failures.
3. The CEO and Board are essentially flying blind when it comes to cyber risk: when the CEO and Board lack formal reporting, it leads to poor understanding of cyber risk, and increased risk of regulatory penalties and reputational damage.

2. The Blueprint: Create an organizational chart that includes:

ANSWER

- Board-level oversight: The board receives quarterly cyber risk report from the CISO. This report ensures visibility and aligns with regulatory expectations.
 - Executive leadership (C-Suite): The CISO reports directly to the CEO of the IT operations which empowers strategic security decisions through IT priorities.
 - Specialized security management and operational roles: the CISO lead overall program, the lead security governance consultants handles policies, risk assessments, training and compliance.
 - Integration points for Business Units: the BISOs act as a liaisons, they report functionally to the CISO but operationally to their business unit leaders thereby ensuring that security supports business output.
3. The Justification Report (1-2 Pages): Explain why this structure fits a 2,500-employee tech firm and how it solves the "visibility" problem for the CEO.

ANSWER

TechGlobal, a fast-growing tech powerhouse with 2,500 employees across 5 global offices. On the surface, everything looks great revenue is up, and the product is scaling. The governance structure transforms TechGlobal from an informal, reactive environment into a structured, proactive security organization.

The proposed structure fit because;

- Separation of duties: this reduces overload on a single individual like the IT Directors and improves efficiency in the organization. The IT Director can focus on operations and collaboration, preventing or reducing cyber risk
- The CISO reports directly to the CEO thereby ensuring that cyber risk is treated as a business risk and regular reporting to the board provide transparency
- The Business Information and Security Officer (BISOs) act as a bridge between security and business unit leaders and they ensure that security controls do not hinder operations.

Deliverables for Task 2

Activity: Role Profiling

Develop comprehensive profiles for:

1. CISO (Chief Information Security Officer)
 2. Security Operations Manager
 3. BISO (Business Information Security Officer)
 4. Security Governance Specialist
 5. Security Architect
- **The Role Definition Dossier:** For each role, you must provide:
 - **Purpose:** Why does this role exist?
 - **The "Top 8":** Eight core responsibilities.
 - **KPIs:** Three metrics that prove they are succeeding.
 - **Authority:** Who do they report to, and what can they sign off on?

ANSWER

A. CISO (Chief Information Security Officer)

1. **Purpose:** is the senior executive responsible for establishing and maintaining the enterprise security vision, strategy, and program.
2. **The "Top 8":** Eight core responsibilities:
 - **Strategic Leadership:** Developing and implementing the overarching security strategy, aligning security initiatives with business objectives and advising executive leadership on all security matters.

- **Program Management:** Establishing the security management framework, overseeing security policies, standards, procedures, and managing the security organization and its resources.
 - **Risk Management:** Identifying and assessing security risks, developing effective risk treatment strategies, and reporting on the organization's risk of posture to executive leadership and the board.
 - **Compliance Oversight:** Ensuring compliance with all relevant security requirements, overseeing the security aspects of regulatory compliance and managing security audit and assessment activities.
 - **Security Operations:** Overseeing security monitoring and incident response, ensuring the effective implementation of security controls and managing security technology and services.
 - Develop and implement enterprise cybersecurity strategy
 - Report cyber risk posture to CEO and Board
 - Establish security governance framework and policies
3. **KPIs:** Three metrics that prove they are succeeding.
 - Reduction in enterprise risk exposure (risk score trends)
 - Board-level reporting frequency and effectiveness
 - Compliance/audit success rate
 4. **Authority:** Who do they report to, and what can they sign off on?
 - **Reports to:** CEO

Authority to:

- Approve security policies and strategy
- Sign off on major security investments
- Escalate risks directly to the Board

B. Security Operations Manager

1. **Purpose:** are at the forefront of an organization's defense, providing continuous monitoring and rapid response to security incidents.
2. **The "Top 8":** Eight core responsibilities.
 - **24/7 Monitoring:** Operating and monitoring security systems around the clock to detect and respond to threats.
 - **Incident Response:** Executing incident response procedures, including containment, eradication, recovery, and post-incident analysis.

- **Threat Intelligence:** Utilizing threat intelligence to proactively identify and mitigate emerging threats.
 - **Forensics:** Conducting digital forensics investigations to determine the scope and impact of security Incidents.
 - **Collaboration:** Collaborating with other IT and business teams during incident response and security Initiatives.
 - Manage Security Operations Center (SOC)
 - Oversee threat detection and monitoring tools (SIEM, EDR)
 - Lead incident detection and response activities
3. **KPIs:** Three metrics that prove they are succeeding.
- Mean Time to Detect (MTTD)
 - Mean Time to Respond (MTTR)
 - Number of incidents detected vs. missed
4. **Authority:** Who do they report to, and what can they sign off on?
- **Reports to:** CISO

Authority to:

- Initiate incident response actions
- Escalate security incidents
- Recommend security tool improvements

C. BISO (Business Information Security Officer)

1. **Purpose:** act as a crucial liaison between the central security function and specific business units.
2. **The "Top 8":** Eight core responsibilities.
 - **Security Advocacy:** Promoting security awareness and best practices within their respective business units.
 - **Risk Assessment:** Conducting business-specific risk assessments and ensuring that security risks are understood and managed within the business context.
 - **Policy Implementation:** Ensuring that enterprise security policies and standards are effectively implemented and adhered to within the business unit.
 - **Security Requirements:** Translating business requirements into security requirements and vice versa.

- **Reporting:** Reporting on the security posture and compliance of their business unit to both business leadership and the CISO
 - Align security initiatives with business unit goals
 - Advise business leaders on cyber risks
 - Ensure security policies are implemented within BUs
3. **KPIs:** Three metrics that prove they are succeeding.
 - Business unit compliance rate
 - Number of security incidents within business units
 - Stakeholder satisfaction (BU leaders)
 4. **Authority:** Who do they report to, and what can they sign off on
 - **Reports to:** CISO

Authority to

- Recommend security controls for business units
- Escalate Business Unit specific risks
- Enforce policy implementation within units

D. Security Governance Specialist

1. **Purpose:** To ensure **security policies, risk management, and compliance frameworks** are properly defined, implemented, and maintained.
2. **The "Top 8":** Eight core responsibilities.
 - Develop and maintain security policies and procedures
 - Conduct risk assessments and maintain risk register
 - Ensure compliance with regulations and standards
 - Coordinate internal and external audits
 - Track remediation of audit findings
 - Define governance frameworks (e.g., NIST CSF)
 - Monitor policy adherence across the organization
 - Provide risk and compliance reports to leadership
3. **KPIs:** Three metrics that prove they are succeeding.
 - Audit findings closure rate
 - Policy compliance rate

- Number of identified vs. mitigated risks
4. **Authority:** Who do they report to, and what can they sign off on
 - **Reports to:** CISO

Authority to:

- Enforce policy compliance
- Recommend risk treatment actions
- Escalate compliance gaps

E. Security Architect

1. **Purpose:** To design and maintain a **secure, scalable, and resilient security architecture** across systems and infrastructure.
2. **The "Top 8":** Eight core responsibilities.
 - Design enterprise security architecture
 - Define security standards for systems and applications
 - Review and approve system designs for security compliance
 - Implement secure-by-design principles
 - Evaluate new technologies for security risks
 - Define network and cloud security architecture
 - Support DevSecOps integration
 - Collaborate with IT and development teams
3. **KPIs:** Three metrics that prove they are succeeding.
 - Number of security issues identified during design phase
 - Reduction in vulnerabilities post-deployment
 - Architecture compliance rate
4. **Authority:** Who do they report to, and what can they sign off on?
 - **Reports to:** CISO

Authority to:

- Approve/reject system designs based on security
- Define architecture standards
- Enforce secure design principles

Deliverables for Task 3

- A. **Committee Charters:** A document detailing the purpose, membership, and "Decision Power" of each group.

ANSWER

Group	Purpose	Membership	Decision Power
Executive Security Council (ESC)	They are the heavy hitters. They provide oversight, leadership, and executive level decision on Cyber risk	CEO CFO CISO IT Director	They approve policies, budget, accept or reject risk appetite and major decision maker during incident
Security Steering Committee(SSC)	They are tactical engine and translate strategy into execution	CISO IT Director Compliance Officer HR personnel Business Unit Representative	They approve operational procedures, allocate resources
Specialized Working Groups (SWG)	They handle technical and operational security issues	Incident Response Team Cloud security team. Security analysts	They respond to incidents, handles security issues, execute security controls and recommend improvement
Business Unit Security Forum (BUSF)	They bridge the gap between business operations and security	BISO Business Units Leaders	They ensure policy adoption in the organization and provide feedback to Security Steering Committee

B. **Interaction Diagram:** How does information flow from a Working Group up to the Board?

ANSWER

Business Unit Security Forum

|

Specialized Working Groups

|

Security Steering Committee

|

Executive Security Council

|

C. **The Governance Calendar:** A sample 12-month schedule of meetings and key milestones

ANSWER

MONTH	KEY MILESTONES
January	Annual Policy Review, Review and annual security strategy approval
February	Policy Updates, Awareness Planning
March	Q1 ESC meeting and budget review
April	Incident response working group exercise
May	Vulnerability Audit
June	Q2 ESC Meeting and mid-year Cyber risk review
July	Security Awareness Campaign
August	Third party risk assessment
September	Q3 ESC Meeting, compliance review
October	Business Continuity Test
November	Budget Planning for Next Year
December	Q4 ESC meeting review and Annual Security Report

Deliverables for Task 4

A. **The TechGlobal RACI Matrix:** A detailed table/spreadsheet.

ANSWER

Activity	Board	CISO	CIO	END USERS
Security Strategy Approval	A	C	C	I
Policy Development	I	R	C	I
Policy Approval	A	C	C	I
Risk Assessment	I	R	C	I
Risk Acceptance	A	C	C	I
Incident Detection	I	A	C	I
Incident Response	I	A	C	I
Incident Reporting	I	R	C	I
Budget Allocation	A	C	C	I
Security Awareness Training	I	R	C	R
Vulnerability Management	I	A	C	I
Access Management	I	A	R	I
Third Party Risk Management	I	R	C	I
Compliance Monitoring	I	R	C	I
Business Continuity Planning	A	C	C	I

Implementation Guide (1 Page): How should the CISO use this matrix to resolve conflicts?

ANSWER

The CISO uses the RACI matrix to resolve conflicts by ensuring the source of truth for accountability and preventing blame shifting and delays.

The Implementation Steps are;

1. Reference: Whenever a conflict arises, the matrix is used to identify who is accountable to make final decision and who executive what to eliminates delay and blame shifting
2. Incorporate RACI Metrix into the Governance structure: the RACI matrix should be attached to all policies documents in the organization, and it should be referred to during audit
3. The RACI Metrix should be enforced through committees: the Security Steering Committees should ensure adherence, executive Security Council enforces accountability while the Specialized Working Groups execute based on the RACI Metrix

4. The RACI Metrix can be use during an incidents like security breach: the Specialized working group should respond, CISO is accountable and the Board are informed, thereby no confusion and faster response as everyone role is define
5. Quarterly Review: the RACI Metrix should be updated as the organization evolves and align with Cybersecurity Framework 2.0 and Risk Management

The RACI Metrix combined with committees transform security from reactive to predictable, accountable governance and empowering growth while managing risk